

# REPORTE EJECUTIVO: GESTIÓN DE RIESGOS DE CIBERSEGURIDAD

**Dirigido a:** Directorio y Gerencia General — Clínica Privada

**Elaborado por:** Responsable de Seguridad de Sistemas

**Fecha:** 27 de agosto de 2026

**Documento:** Reporte Ejecutivo de Estado de Riesgos e Inversiones Prioritarias

## RESUMEN EJECUTIVO Y DIAGNÓSTICO DE SITUACIÓN

### 1. Contexto Operativo y Alcance

Nuestra institución médica cuenta con una plantilla de **120 empleados**, atiende un promediando **800 pacientes diarios** y gestiona activos de información altamente sensibles que incluyen Historias Clínicas Electrónicas (HCE), datos de filiación, plataformas de facturación y validaciones con obras sociales.

### 2. Diagnóstico tras Auditoría Externa

Tras la reciente auditoría de seguridad realizada en nuestras instalaciones, se identificaron vulnerabilidades críticas en la madurez de la gestión de riesgos tecnológicos. La falta de controles modernos exponía a la clínica a tres escenarios de alto impacto:

- **Parálisis Operativa:** Imposibilidad de prestar atención médica por caída de sistemas centrales.
- **Infracción Legal y Normativa:** Fuga o exfiltración de datos sensibles de salud de los pacientes.
- **Pérdida Financiera:** Interrupción en los procesos de facturación e imposibilidad de validar coberturas de obras sociales en tiempo real.

Para mitigar estos escenarios, el área de seguridad formalizó el **Registro Inicial de Riesgos** en la plataforma SimpleRisk, priorizando los activos críticos e identificando las salvaguardas necesarias para garantizar la continuidad operativa.

## TOP 5 RIESGOS POR NIVEL DE SEVERIDAD

Utilizando la matriz de evaluación semicuantitativa  $5 \times 5$  ( $\text{Nivel} = \text{Probabilidad} \times \text{Impacto}$ ), se han categorizado los 5 riesgos de mayor criticidad para la dirección:

| Ranking | ID  | Nombre del Riesgo                            | Activo Afectado            | Categoría                   | Prob (1-5) | Imp (1-5) | Nivel de Riesgo |
|---------|-----|----------------------------------------------|----------------------------|-----------------------------|------------|-----------|-----------------|
| #1      | R01 | Infección por Ransomware en Servidor HCE     | Servidor de HCE            | Disponibilidad / Operativo  | 4          | 5         | 20 (CRÍTICO)    |
| #2      | R02 | Exfiltración de Datos por Phishing           | Base de Datos de Pacientes | Confidencialidad / Legal    | 4          | 5         | 20 (CRÍTICO)    |
| #3      | R07 | Interrupción Eléctrica en Centro de Cómputos | Servidores Locales         | Disponibilidad / Físico     | 3          | 4         | 12 (ALTO)       |
| #4      | R06 | Pérdida de Backups por Falla en Storage      | Storage NAS de Respaldo    | Disponibilidad / Integridad | 2          | 5         | 10 (ALTO)       |
| #5      | R04 | Caída del Enlace de Internet Principal       | Portal Web de Turnos       | Disponibilidad              | 3          | 3         | 9 (MEDIO)       |

#### Detalle de Exposición de los Riesgos Críticos:

- **R01 (Ransomware):** El cifrado malintencionado de la base de datos de Historias Clínicas paralizaría la atención de los 800 pacientes diarios de forma inmediata.
- **R02 (Phishing):** La falta de un factor multifactor de autenticación (MFA) en los 120 correos corporativos expone a la clínica a la fuga masiva de datos médicos y multas regulatorias severas.
- **R07 (Corte Eléctrico):** Microcortes o fallas prolongadas en la red comercial pueden provocar la corrupción física de las bases de datos de pacientes y servidores.

### PÁGINA 3: PLANES DE ACCIÓN, PRESUPUESTO Y RECOMENDACIONES

#### 1. Estado de los Planes de Acción para Riesgos Altos y Críticos

Se estructuraron tres proyectos de mitigación directa con fechas límite y responsables asignados para reducir el riesgo residual a niveles aceptables:

| Proyecto / Plan de Acción                                                  | Riesgo Asociado | Responsable                               | Presupuesto        | Fecha Límite | Estado Inicial |
|----------------------------------------------------------------------------|-----------------|-------------------------------------------|--------------------|--------------|----------------|
| <b>Plan 1:</b><br>Despliegue de EDR centralizado y segmentación VLAN       | <b>R01</b>      | Jefe de Infraestructura TI<br>(sec_admin) | <b>\$4,500 USD</b> | 30/11/2026   | Planificado    |
| <b>Plan 2:</b><br>Implementación de MFA obligatoria y Antiphishing         | <b>R02</b>      | Oficial de Seguridad<br>(analyst_med)     | <b>\$2,000 USD</b> | 15/10/2026   | Aprobado       |
| <b>Plan 3:</b><br>Adquisición e instalación de UPS Online 10kVA Redundante | <b>R07</b>      | Director de Mantenimiento<br>(sec_admin)  | <b>\$6,000 USD</b> | 20/12/2026   | En Cotización  |



**Presupuesto Total Requerido para Mitigación: \$12,500 USD**

## **2. Recomendaciones Prioritarias para la Gerencia**

1. **Aprobación de Presupuesto:** Aprobar de manera prioritaria la asignación de **\$12,500 USD** para la ejecución de los tres planes de acción antes de finalizar el último trimestre del año.
2. **Institucionalización de la Política de MFA:** Emitir una directiva corporativa que establezca la obligatoriedad del uso de Autenticación de Doble Factor (MFA) para todo el personal (médico, administrativo y directivo).
3. **Revisión Trimestral de Riesgos:** Formalizar reuniones trimestrales de revisión del catálogo de SimpleRisk entre el Oficial de Seguridad y el Directorio para monitorear el avance del riesgo residual y nuevas amenazas.